

DATA CLASSIFICATION POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Data Classification Policy
Document ID	POL-DCL-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC2.1 and CC6.7, and GDPR Articles 5 and 32. It uses three classifications, because a fourth would not change how anything is handled here.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 THE THREE CLASSIFICATIONS.....6

6 HANDLING6

7 CHANGING A CLASSIFICATION6

8 RECORDS.....7

9 EXCEPTIONS7

10 REFERENCE.....7

11 DOCUMENT POLICY HISTORY.....7

1 Overview and Purpose

Classification exists so that everything else can refer to it. When another policy says “Restricted”, this Policy is what that means.

PromptHalo Technologies (“the Company”) uses three levels. A finer scheme would create decisions without changing the handling that follows from them.

2 Scope

This Policy covers all Company and client information in any form, and applies wherever it is held — cloud services, code repositories, documents and messages.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The person who creates or receives information classifies it. Where it is unclear, the higher classification applies until the Accountable Party decides otherwise. [SOC 2: CC2.1]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
5. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
6. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
7. **Security Officer** — the individual accountable for day-to-day operation of the security program.

8. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
9. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 The Three Classifications

1. **Internal** — the Company's own working information: plans, drafts, internal discussion. Not public, but its disclosure would be embarrassing rather than harmful. Most information is this. [SOC 2: CC2.1]
2. **Confidential** — information whose disclosure would harm the Company or a client: client deliverables, commercial terms, personal data of personnel. [SOC 2: CC2.1 · GDPR Art. 5]
3. **Restricted** — information whose disclosure would cause serious harm: client security findings, credentials, assessment evidence, client personal data. This is the class the rest of the library builds its strictest rules around. [SOC 2: CC2.1, CC6.7]
4. Anything not classified is treated as Confidential. There is no public class, because the Company publishes little and what it does publish is a deliberate act rather than a classification. [SOC 2: CC2.1]

6 Handling

1. Internal and Confidential information is held in Company cloud services and shared through them rather than by attachment. [SOC 2: CC6.7]
2. Restricted information is not transmitted over unencrypted channels, not held in personal accounts, personal cloud storage or personal AI tools, and not placed on removable media. It is handled only on Company-provided equipment. [SOC 2: CC6.7 · C1.1]
3. Classification is recorded against assets in the inventory so that protection requirements can be applied and evidenced rather than assumed. [SOC 2: CC2.1]
4. Client information carries whatever classification the client's agreement requires where that is higher than the Company's own assessment. [SOC 2: CC2.1, CC9.2]
5. Information carries its classification where the medium allows it — a header on a document, a label on a shared drive folder, a note in a repository README. Where it does not, the location carries it instead: everything in a folder marked Restricted is Restricted. Nobody is expected to label an individual chat message. [SOC 2: CC2.1]

7 Changing a Classification

Classification is not permanent. Two things change it, and both are worth stating because neither is obvious.

1. **Aggregation** raises it. Individually innocuous records can combine into something sensitive — a list of client names is Confidential, but the same list annotated with their unpatched

vulnerabilities is Restricted. Where information is combined, the classification of the result is assessed rather than inherited from its parts. [SOC 2: CC2.1]

2. Time lowers it. A finding that has been remediated and disclosed, or a plan that has shipped, may no longer warrant its original level. Declassification is decided by the Accountable Party and recorded against the asset, and client information is never declassified without the client's agreement. [SOC 2: CC2.1, CC9.2]

8 Records

1. Classification recorded against assets in the inventory. [SOC 2: CC2.1]
2. Any client-specific classification requirements taken from agreements. [SOC 2: CC9.2]

9 Exceptions

Where information must be handled below its classification — a client requiring delivery through a channel the Company would not choose — the position is recorded by the Accountable Party with the compensating measure and a review date.

10 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.1, CC6.7]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. POL-ENC-001 Encryption Policy [SOC 2: CC6.7]
4. POL-DRD-001 Data Retention and Disposal Policy [SOC 2: CC6.5]
5. POL-AUP-001 Acceptable Use Policy [SOC 2: CC6.7]
6. EU General Data Protection Regulation, Articles 5 and 32

11 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release